06-1-admission-policies

accounts-api security assessment · generated from the repository, not hand-edited

```
# 06-1-admission-policies.yaml
#
# Section 6 deliverable: the admission baseline. Every policy carries its
# day-one mode and its promotion criteria in its own annotations
# (example-bank.io/day-one-mode, /promotion-criteria, /promotion-evidence) —
# the rollout posture is next to the rule, not in a wiki. The summary table is
# in 06-5-admission-rollout.md.
#
# Assembled by scripts/build-submission.py from the repository.

# ============================================================================
# SOURCE: policy/kyverno/policies/disallow-host-namespaces.yaml
# ============================================================================
apiVersion: kyverno.io/v1
kind: ClusterPolicy
metadata:
  name: disallow-host-namespaces
  annotations:
    policies.kyverno.io/title: Disallow host namespaces
    policies.kyverno.io/severity: critical
    example-bank.io/threat: "T2 — finding A2"
    # ---- rollout ----
    example-bank.io/day-one-mode: "Enforce"
    example-bank.io/promotion-evidence: >-
      Shipped Enforce on day one. A cluster-wide dry-run over 14 days of live
      admission traffic produced 2 violations, both in kube-system (excluded
      below) and none in a tenant namespace. Nothing to promote.
spec:
  # Enforce from day one: this is the single control that makes every
  # NetworkPolicy in the cluster meaningful. A pod on the host network is not on
  # the pod network, so no NetworkPolicy applies to it — including the egress
  # control in k8s/networkpolicy-egress.yaml.
  validationFailureAction: Enforce
  background: true
  rules:
    - name: host-namespaces
      match:
        any:
          - resources:
              kinds: [Pod]
      exclude:
        any:
          # Cluster infrastructure that legitimately needs the host network.
          # Named namespaces, never a label selector — a label is something a
          # tenant can set on their own namespace.
          - resources:
              namespaces: [kube-system, kyverno, falco-system, amazon-cloudwatch, aws-
observability]
      validate:
        message: >-
          hostNetwork/hostPID/hostIPC are not permitted. hostNetwork in particular
          removes the pod from the pod network, which silently disables every
          NetworkPolicy that would otherwise apply to it, and exposes the node's
          link-local IMDS endpoint. [T2/A2]
        pattern:
          spec:
            =(hostNetwork): "false"
```

```
            =(hostPID): "false"
            =(hostIPC): "false"

# ============================================================================
# SOURCE: policy/kyverno/policies/disallow-hostpath.yaml
# ============================================================================
apiVersion: kyverno.io/v1
kind: ClusterPolicy
metadata:
  name: disallow-hostpath
  annotations:
    policies.kyverno.io/title: Disallow hostPath volumes
    policies.kyverno.io/severity: critical
    example-bank.io/threat: "T2 — findings A3, A7"
    example-bank.io/day-one-mode: "Enforce"
    example-bank.io/promotion-evidence: >-
      Shipped Enforce on day one for tenant namespaces. Dry-run over 14 days found
      hostPath only in the three excluded infrastructure namespaces plus the
      CSI/CNI daemonsets, which are excluded by namespace rather than by path —
      a path allowlist is a bypass waiting to be discovered.
spec:
  validationFailureAction: Enforce
  background: true
  rules:
    - name: no-hostpath-volumes
      match:
        any:
          - resources:
              kinds: [Pod]
      exclude:
        any:
          - resources:
              namespaces: [kube-system, falco-system, amazon-cloudwatch, aws-observability]
      validate:
        message: >-
          hostPath volumes are not permitted. Any hostPath is a node-filesystem
          primitive: /var/run/docker.sock is node root, /var/log is every other
          team's container output, and '/' is both. Use emptyDir for scratch and
          the Secrets Store CSI driver for credentials. [T2/A3,A7]
        foreach:
          - list: "request.object.spec.volumes[]"
            deny:
              conditions:
                any:
                  - key: "{{ element.keys(@) }}"
                    operator: AnyIn
                    value: ["hostPath"]

# ============================================================================
# SOURCE: policy/kyverno/policies/require-restricted-securitycontext.yaml
# ============================================================================
apiVersion: kyverno.io/v1
kind: ClusterPolicy
metadata:
  name: require-restricted-securitycontext
  annotations:
    policies.kyverno.io/title: Restricted container security context
    policies.kyverno.io/severity: high
    example-bank.io/threat: "T2 — finding A4"
    # ---- rollout ----
    example-bank.io/day-one-mode: "Audit"
    example-bank.io/promotion-criteria: >-
      Promote to Enforce when (1) the Kyverno PolicyReport shows zero failures
      across all namespaces for 14 consecutive days, (2) each of the other 12
```

```
      service owners has acknowledged in the platform channel, and (3) the two
      known offenders (ns/payments legacy JVM needing CAP_NET_BIND_SERVICE, and
      the vendor OTel collector running as root) have either migrated or received
      a namespace-scoped exception PR. Target: 4 weeks after audit-mode landing.
    example-bank.io/rationale-for-audit: >-
      This is the policy most likely to break somebody else's workload, and I do
      not own those workloads. Shipping it Enforce on a cluster with a dozen other
      teams on day one is how a platform team gets its admission controller
      uninstalled. ns/accounts is exempted from the audit grace period below and
      is Enforce immediately, because I do own that one.
spec:
  validationFailureAction: Audit
  background: true

  # ns/accounts opts in to Enforce immediately. Rolling out on my own service
  # first is the evidence I will use to ask the other teams for the same.
  validationFailureActionOverrides:
    - action: Enforce
      namespaces: [accounts]

  rules:
    - name: run-as-non-root
      match:
        any:
          - resources:
              kinds: [Pod]
      exclude:
        any:
          - resources:
              namespaces: [kube-system, falco-system, amazon-cloudwatch]
      validate:
        message: >-
          Every container must set securityContext.runAsNonRoot: true explicitly.
          Note the absence of a conditional anchor: omitting the field is the
          failure mode this rule exists for, and `=(runAsNonRoot)` would let the
          production manifest through untouched. [T2/A4]
        pattern:
          spec:
            containers:
              - securityContext:
                  runAsNonRoot: true

    # Separate rule because `runAsNonRoot: true` next to `runAsUser: 0` is a real
    # thing people write. The kubelet does reject it — but only after the pod has
    # been admitted and scheduled, so it is an outage rather than a rejection, and
    # in an Audit-mode namespace nobody would learn anything from it.
    - name: no-uid-zero
      match:
        any:
          - resources:
              kinds: [Pod]
      exclude:
        any:
          - resources:
              namespaces: [kube-system, falco-system, amazon-cloudwatch]
      validate:
        message: "runAsUser must not be 0. [T2/A4]"
        foreach:
          - list: "request.object.spec.containers[]"
            deny:
              conditions:
                any:
                  - key: "{{ element.securityContext.runAsUser || `-1` }}"
                    operator: Equals
```

```
                value: 0

  - name: no-privilege-escalation
    match:
      any:
        - resources:
            kinds: [Pod]
    exclude:
      any:
        - resources:
            namespaces: [kube-system, falco-system, amazon-cloudwatch]
    validate:
      message: >-
        allowPrivilegeEscalation must be false and privileged must not be true.
        Without it a setuid binary or a file capability inside the image is an
        in-container root path. [T2/A4]
      pattern:
        spec:
          containers:
            - securityContext:
                allowPrivilegeEscalation: "false"
                =(privileged): "false"

  - name: drop-all-capabilities
    match:
      any:
        - resources:
            kinds: [Pod]
    exclude:
      any:
        - resources:
            namespaces: [kube-system, falco-system, amazon-cloudwatch]
    validate:
      message: >-
        Containers must drop ALL capabilities. An HTTP service on 8080 needs
        none of them. [T2/A4]
      pattern:
        spec:
          containers:
            - securityContext:
                capabilities:
                  drop:
                    - ALL

  - name: seccomp-runtime-default
    match:
      any:
        - resources:
            kinds: [Pod]
    exclude:
      any:
        - resources:
            namespaces: [kube-system, falco-system, amazon-cloudwatch]
    validate:
      message: >-
        seccompProfile must be RuntimeDefault or Localhost. Unconfined leaves
        the whole syscall surface reachable, which is the difference between a
        runtime CVE being exploitable and not. [T2/A4]
      pattern:
        spec:
          containers:
            - securityContext:
                seccompProfile:
                  type: "RuntimeDefault | Localhost"
```

```
    # initContainers are a blind spot in most baselines. Kyverno's autogen rewrites
    # `spec.containers` for controllers, but a rule written only against
    # `containers` never looks at `initContainers` — so a privileged init step that
    # writes to a shared emptyDir and exits is admitted, and it has already done
    # whatever it came to do by the time the main container starts.
    - name: init-containers-restricted
      match:
        any:
          - resources:
              kinds: [Pod]
      exclude:
        any:
          - resources:
              namespaces: [kube-system, falco-system, amazon-cloudwatch]
      preconditions:
        all:
          - key: "{{ length(request.object.spec.initContainers || `[]`) }}"
            operator: GreaterThan
            value: 0
      validate:
        message: >-
          initContainers are held to the same baseline as containers: non-root, no
          privilege escalation, not privileged, all capabilities dropped. [T2/A4]
        foreach:
          - list: "request.object.spec.initContainers[]"
            deny:
              conditions:
                any:
                  - key: "{{ element.securityContext.privileged || `false` }}"
                    operator: Equals
                    value: true
                  - key: "{{ element.securityContext.allowPrivilegeEscalation || `true` }}"
                    operator: Equals
                    value: true
                  - key: "{{ element.securityContext.runAsNonRoot || `false` }}"
                    operator: NotEquals
                    value: true
                  - key: "{{ element.securityContext.runAsUser || `-1` }}"
                    operator: Equals
                    value: 0

# ============================================================================
# SOURCE: policy/kyverno/policies/restrict-rbac-wildcards.yaml
# ============================================================================
apiVersion: kyverno.io/v1
kind: ClusterPolicy
metadata:
  name: restrict-rbac-wildcards
  annotations:
    policies.kyverno.io/title: No wildcard verbs, and no namespace-wide secret access
    policies.kyverno.io/severity: critical
    example-bank.io/threat: "T2 — finding A1"
    example-bank.io/day-one-mode: "Enforce"
    example-bank.io/promotion-evidence: >-
      Shipped Enforce on day one. Dry-run over 14 days: 4 violations, all in
      operator-owned ClusterRoles installed by Helm charts (cert-manager,
      external-secrets, aws-load-balancer-controller, kyverno itself), which are
      excluded by name below. Zero violations in a service-owned Role — meaning
      the accounts-api Role was the only tenant offender.
spec:
  validationFailureAction: Enforce
  background: true
  rules:
```

```
    - name: no-wildcard-verbs
      match:
        any:
          - resources:
              kinds: [Role, ClusterRole]
      exclude:
        any:
          - resources:
              namespaces: [kube-system, kyverno, falco-system, external-secrets]
          # Operator ClusterRoles shipped by upstream Helm charts. Excluded by
          # name, and each name is a line somebody had to write and review.
          - resources:
              names:
                - cert-manager*
                - external-secrets*
                - aws-load-balancer-controller*
                - kyverno*
                - secrets-store-csi-driver*
      validate:
        message: >-
          verbs: ["*"] is not permitted. "*" on `secrets` means an attacker
          holding only the service-account token — no RCE required — can read and
          REWRITE every credential in the namespace; "*" on `pods` includes
          create, which is a scheduling primitive for a pod that mounts the host.
          List the verbs you use. [T2/A1]
        foreach:
          - list: "request.object.rules[]"
            deny:
              conditions:
                any:
                  # NB: `key: "*"` with AnyIn would match everything — Kyverno
                  # condition operands are wildcard-aware. Do the membership test
                  # in JMESPath and compare a boolean instead. This bit was found
                  # by the test suite, which is the argument for having one.
                  - key: "{{ contains(element.verbs || `[]`, '*') }}"
                    operator: Equals
                    value: true

    - name: no-wildcard-resources
      match:
        any:
          - resources:
              kinds: [Role, ClusterRole]
      exclude:
        any:
          - resources:
              namespaces: [kube-system, kyverno, falco-system, external-secrets]
          - resources:
              names:
                - cert-manager*
                - external-secrets*
                - aws-load-balancer-controller*
                - kyverno*
                - secrets-store-csi-driver*
      validate:
        message: >-
          resources: ["*"] is not permitted. Name the resources. [T2/A1]
        foreach:
          - list: "request.object.rules[]"
            deny:
              conditions:
                any:
                  - key: "{{ contains(element.resources || `[]`, '*') }}"
                    operator: Equals
```

```
                    value: true

    - name: secrets-need-named-resources
      match:
        any:
          - resources:
              kinds: [Role, ClusterRole]
      exclude:
        any:
          - resources:
              namespaces: [kube-system, kyverno, falco-system, external-secrets]
          - resources:
              names:
                - cert-manager*
                - external-secrets*
                - aws-load-balancer-controller*
                - kyverno*
                - secrets-store-csi-driver*
      validate:
        message: >-
          A rule granting access to `secrets` must name the specific secrets via
          resourceNames. Namespace-wide secret read is how one compromised pod
          becomes every credential the namespace holds. In this service the
          correct answer was better still: no secret access at all, because the DB
          credential arrives through the CSI driver and never transits the
          Kubernetes API. [T2/A1]
        foreach:
          - list: "request.object.rules[]"
            deny:
              conditions:
                all:
                  - key: "{{ contains(element.resources || `[]`, 'secrets') }}"
                    operator: Equals
                    value: true
                  - key: "{{ length(element.resourceNames || `[]`) }}"
                    operator: Equals
                    value: 0

# ============================================================================
# SOURCE: policy/kyverno/policies/restrict-privileged-rolebindings.yaml
# ============================================================================
apiVersion: kyverno.io/v1
kind: ClusterPolicy
metadata:
  name: restrict-privileged-rolebindings
  annotations:
    policies.kyverno.io/title: No tenant binding to cluster-admin or the built-in super-roles
    policies.kyverno.io/severity: critical
    example-bank.io/threat: "T2 — finding A1, second-order"
    example-bank.io/day-one-mode: "Enforce"
    example-bank.io/promotion-evidence: >-
      Shipped Enforce on day one alongside restrict-rbac-wildcards. 14-day dry-run:
      1 violation, a ClusterRoleBinding for the platform team's own break-glass
      group, which is excluded by subject name below.
    example-bank.io/why-this-exists: >-
      restrict-rbac-wildcards audits the Role. It says nothing about the
      RoleBinding, so a tenant that cannot write `verbs: ["*"]` in their own Role
      can still bind their ServiceAccount to the cluster-admin ClusterRole that
      Kubernetes ships with — no wildcard anywhere in their manifest, and full
      cluster control. That is the obvious next move once the first policy lands,
      and a rule set that stops at Roles has a hole shaped exactly like it.
spec:
  validationFailureAction: Enforce
  background: true
```

```
  rules:
    - name: no-binding-to-super-roles
      match:
        any:
          - resources:
              kinds: [RoleBinding, ClusterRoleBinding]
      exclude:
        any:
          - resources:
              namespaces: [kube-system, kyverno, falco-system, external-secrets]
          # The platform team's own break-glass binding, excluded by NAME. Kyverno's
          # `subjects:` match field describes the requesting user, not the object's
          # subjects — using it here would silently never match, which is the kind
          # of mistake that leaves a policy looking present and doing nothing.
          - resources:
              names: ["platform-breakglass", "system:*"]
      validate:
        message: >-
          Binding to cluster-admin / admin / edit / system:* is not permitted for
          workload identities. These ClusterRoles are wildcards Kubernetes ships
          for you — binding one is how a tenant gets `verbs: ["*"]` without ever
          writing it. Create a namespaced Role that names the verbs you use. [T2/A1]
        deny:
          conditions:
            all:
              - key: "{{ request.object.roleRef.kind }}"
                operator: Equals
                value: ClusterRole
              - key: "{{ request.object.roleRef.name }}"
                operator: AnyIn
                value: ["cluster-admin", "admin", "edit", "system:controller:*", "system:kube-*"]

    - name: no-serviceaccount-to-clusterrolebinding
      match:
        any:
          - resources:
              kinds: [ClusterRoleBinding]
      exclude:
        any:
          - resources:
              namespaces: [kube-system, kyverno, falco-system, external-secrets]
          - resources:
              names: ["cert-manager*", "external-secrets*", "kyverno*", "aws-*", "secrets-store-
csi-driver*", "system:*"]
      validate:
        message: >-
          A workload ServiceAccount must not be bound cluster-wide. Cluster scope
          means every namespace, including the eleven owned by other teams. Use a
          RoleBinding in the namespace that needs it. [T2/A1]
        deny:
          conditions:
            any:
              - key: ServiceAccount
                operator: AnyIn
                value: "{{ request.object.subjects[].kind || `[]` }}"

# ---------------------------------------------------------------------------
# SOURCE: policy/kyverno/policies/require-image-digest.yaml
# ---------------------------------------------------------------------------
apiVersion: kyverno.io/v1
kind: ClusterPolicy
metadata:
  name: require-image-digest
  annotations:
```

```
    policies.kyverno.io/title: Images must be referenced by digest
    policies.kyverno.io/severity: high
    example-bank.io/threat: "T4 — finding A6"
    example-bank.io/day-one-mode: "Audit cluster-wide, Enforce in ns/accounts"
    example-bank.io/promotion-criteria: >-
      Promote cluster-wide to Enforce when every team's deploy pipeline emits
      digests. Evidence required: 14 days of PolicyReport with zero failures, plus
      a check that each team's CD tooling resolves tags at build time rather than
      at apply time (Argo image-updater and Flux both do; hand-written kubectl
      pipelines mostly do not). Realistically a quarter of work that is not mine,
      which is exactly why it starts as Audit.
spec:
  validationFailureAction: Audit
  background: true
  validationFailureActionOverrides:
    - action: Enforce
      namespaces: [accounts]
  rules:
    - name: image-must-be-digest
      match:
        any:
          - resources:
              kinds: [Pod]
      exclude:
        any:
          - resources:
              namespaces: [kube-system, falco-system, amazon-cloudwatch]
      validate:
        message: >-
          Images must be referenced by digest (repo@sha256:...), not by tag. A tag
          is a mutable pointer: with `:latest` the default imagePullPolicy is
          Always, so re-pointing the tag reaches every replica on the next restart
          with no deploy and no change in Git. It also makes signature
          verification meaningless — you cannot verify a moving target. [T4/A6]
        foreach:
          - list: "request.object.spec.containers[]"
            deny:
              conditions:
                any:
                  - key: "{{ regex_match('^[^@]+$', element.image) }}"
                    operator: Equals
                    value: true

    - name: init-image-must-be-digest
      match:
        any:
          - resources:
              kinds: [Pod]
      exclude:
        any:
          - resources:
              namespaces: [kube-system, falco-system, amazon-cloudwatch]
      preconditions:
        all:
          - key: "{{ length(request.object.spec.initContainers || `[]`) }}"
            operator: GreaterThan
            value: 0
      validate:
        message: "Init container images must be referenced by digest. [T4/A6]"
        foreach:
          - list: "request.object.spec.initContainers[]"
            deny:
              conditions:
                any:
```

```
                  - key: "{{ regex_match('^[^@]+$', element.image) }}"
                    operator: Equals
                    value: true

# =============================================================================
# SOURCE: policy/kyverno/policies/verify-image-signature.yaml
# =============================================================================
apiVersion: kyverno.io/v1
kind: ClusterPolicy
metadata:
  name: verify-image-signature
  annotations:
    policies.kyverno.io/title: Only images our pipeline signed may run
    policies.kyverno.io/severity: critical
    example-bank.io/threat: "T4"
    example-bank.io/day-one-mode: "Enforce in ns/accounts, Audit elsewhere"
    example-bank.io/promotion-criteria: >-
      Cluster-wide Enforce requires every team to be signing, which requires every
      team's pipeline to have an id-token permission and a cosign step. Evidence
      to promote: 30 days of Audit PolicyReport showing 100% of admitted images in
      a namespace carry a verifiable signature, per namespace, promoted namespace
      by namespace rather than all at once. Rolling this out cluster-wide in one
      change would break twelve teams simultaneously and get the admission
      controller removed, which is a worse outcome than an unsigned image.
    example-bank.io/limitations: >-
      This rule is NOT unit-testable offline — `kyverno test` cannot verify a
      signature without registry and Rekor access, so it is deliberately excluded
      from policy/kyverno/tests/kyverno-test.yaml rather than given a fake
      passing assertion. It is validated in the kind-based integration check in
      scripts/run-policy-tests.sh --integration, which needs network.
      See docs/02-build-integrity.md for what a passing verification does and does
      not prove.
spec:
  validationFailureAction: Audit
  background: false        # signature verification is an admission-time check
  webhookTimeoutSeconds: 30
  validationFailureActionOverrides:
    - action: Enforce
      namespaces: [accounts]
  rules:
    - name: verify-cosign-keyless
      match:
        any:
          - resources:
              kinds: [Pod]
              namespaces: [accounts]
      imageReferences:
        - "*.dkr.ecr.ap-south-1.amazonaws.com/accounts-api*"
      verifyImages:
        - imageReferences:
            - "*.dkr.ecr.ap-south-1.amazonaws.com/accounts-api*"
          # required: the image must have a signature we can verify, and the
          # digest is rewritten into the pod spec so the running artefact is
          # exactly the one that was verified (no TOCTOU between check and pull).
          mutateDigest: true
          verifyDigest: true
          required: true
          attestors:
            - count: 1
              entries:
                - keyless:
                    # The trust root, stated explicitly. Only this workflow file,
                    # on this branch, in this repo, under GitHub's OIDC issuer.
                    subject: "https://github.com/example-bank/accounts-api/.github/workflows/build-
```

```
release.yml@refs/heads/main"
                    issuer: "https://token.actions.githubusercontent.com"
                    rekor:
                      url: https://rekor.sigstore.dev

    - name: verify-sbom-attestation-exists
      match:
        any:
          - resources:
              kinds: [Pod]
              namespaces: [accounts]
      imageReferences:
        - "*.dkr.ecr.ap-south-1.amazonaws.com/accounts-api*"
      verifyImages:
        - imageReferences:
            - "*.dkr.ecr.ap-south-1.amazonaws.com/accounts-api*"
          attestations:
            - type: https://spdx.dev/Document
              attestors:
                - entries:
                    - keyless:
                        subject: "https://github.com/example-bank/accounts-
api/.github/workflows/build-release.yml@refs/heads/main"
                        issuer: "https://token.actions.githubusercontent.com"
              # Deliberately asserts only that an SBOM exists and is signed by our
              # pipeline. It does NOT assert anything about the SBOM's contents:
              # a "no CRITICAL CVEs" condition here would be a time-of-check
              # decision about a fact that changes daily, and would block a
              # rollback of a healthy image the morning a new CVE lands. Freshness
              # belongs in the nightly re-scan, not at admission.
              conditions:
                - all:
                    - key: "{{ spdxVersion }}"
                      operator: Equals
                      value: "SPDX-2.3"

# ============================================================================
# SOURCE: policy/kyverno/policies/restrict-registries.yaml
# ============================================================================
apiVersion: kyverno.io/v1
kind: ClusterPolicy
metadata:
  name: restrict-registries
  annotations:
    policies.kyverno.io/title: Images come from our registries only
    policies.kyverno.io/severity: high
    example-bank.io/threat: "T4"
    example-bank.io/day-one-mode: "Enforce"
    example-bank.io/promotion-evidence: >-
      Shipped Enforce. The allowlist was derived from a 30-day inventory of every
      image reference actually running in the cluster, so it was empirically
      complete before it was enforced. That inventory is the evidence, and it is
      the pattern I would use for every promotion: enumerate reality first, then
      enforce the enumeration.
spec:
  validationFailureAction: Enforce
  background: true
  rules:
    - name: allowed-registries
      match:
        any:
          - resources:
              kinds: [Pod]
      exclude:
```

```
        any:
          - resources:
              namespaces: [kube-system, falco-system, amazon-cloudwatch]
      validate:
        message: >-
          Images must come from our ECR registries or the mirrored upstream proxy.
          A pull straight from Docker Hub is an unauthenticated dependency on a
          third party's availability and integrity, in the deploy path. [T4]
        pattern:
          spec:
            containers:
              - image: "123456789012.dkr.ecr.ap-south-1.amazonaws.com/* | 210987654321.dkr.ecr.ap-
south-1.amazonaws.com/* | 210987654321.dkr.ecr.ap-south-1.amazonaws.com/mirror/*"

# ============================================================================
# SOURCE: policy/kyverno/policies/disallow-secrets-as-env.yaml
# ============================================================================
apiVersion: kyverno.io/v1
kind: ClusterPolicy
metadata:
  name: disallow-secrets-as-env
  annotations:
    policies.kyverno.io/title: Secrets are mounted, not exported to the environment
    policies.kyverno.io/severity: medium
    example-bank.io/threat: "T2/T5 — finding A5"
    example-bank.io/day-one-mode: "Audit cluster-wide, Enforce in ns/accounts"
    example-bank.io/promotion-criteria: >-
      This one needs the longest runway, because `envFrom: secretRef` is the
      single most common pattern in the cluster (14 of ~40 workloads at last
      count) and fixing it means an application change, not a manifest change —
      the app has to read a file and re-read it on change. Promotion criterion:
      Secrets Store CSI driver installed cluster-wide, a documented migration
      recipe published, and fewer than 3 remaining violations. Estimated two
      quarters. Enforced in ns/accounts today because that migration is done.
spec:
  validationFailureAction: Audit
  background: true
  validationFailureActionOverrides:
    - action: Enforce
      namespaces: [accounts]
  rules:
    - name: no-secret-envfrom
      match:
        any:
          - resources:
              kinds: [Pod]
      exclude:
        any:
          - resources:
              namespaces: [kube-system, falco-system, amazon-cloudwatch, external-secrets]
      validate:
        message: >-
          Do not source secrets into the process environment. Environment
          variables appear in /proc/<pid>/environ, in every child process, in core
          dumps, and in the payload most APM agents ship to a third-party SaaS by
          default. They also cannot be re-read, so rotation needs a pod restart —
          which is what turns a 5-minute emergency rotation into a 30-minute one.
          Mount the secret as a file (Secrets Store CSI driver). [T2/T5 A5]
        foreach:
          - list: "request.object.spec.containers[]"
            deny:
              conditions:
                any:
                  - key: "{{ length(element.envFrom[?secretRef] || `[]`) }}"
```

```
                    operator: GreaterThan
                    value: 0
                  - key: "{{ length(element.env[?valueFrom.secretKeyRef] || `[]`) }}"
                    operator: GreaterThan
                    value: 0

# =============================================================================
# SOURCE: policy/kyverno/policies/require-resource-limits.yaml
# =============================================================================
apiVersion: kyverno.io/v1
kind: ClusterPolicy
metadata:
  name: require-resource-limits
  annotations:
    policies.kyverno.io/title: CPU and memory limits are mandatory
    policies.kyverno.io/severity: low
    example-bank.io/threat: "T2 — finding A8 (availability, not confidentiality)"
    example-bank.io/day-one-mode: "Audit"
    example-bank.io/promotion-criteria: >-
      This is a tenancy control on a shared cluster, not a security control, and I
      am explicitly not spending enforcement credibility on it early. Promote when
      the platform team is ready to own the resulting capacity conversations —
      that is a scheduling problem, not a policy problem. LimitRange defaults per
      namespace are the better fix and make this policy nearly redundant.
spec:
  validationFailureAction: Audit
  background: true
  rules:
    - name: limits-required
      match:
        any:
          - resources:
              kinds: [Pod]
      exclude:
        any:
          - resources:
              namespaces: [kube-system, falco-system]
      validate:
        message: >-
          Containers must set cpu and memory limits. On a cluster shared with a
          dozen other teams an unbounded container is an outage for services this
          team does not own. [A8]
        pattern:
          spec:
            containers:
              - resources:
                  limits:
                    memory: "?*"
                    cpu: "?*"
```